



**Institución
Universitaria
de Envigado**
VIGILADA MINEDUCACIÓN

FACULTAD DE INGENIERÍA

ANEXO TÉCNICO DEL CASO DE ESTUDIO

Coopaburrá: la evidencia técnica del diagnóstico

SIO0010 • Técnicas Criptográficas

Especialización en Seguridad de la Información de las Organizaciones



QUÉ ES

La materia prima del inventario criptográfico

COMPLEMENTA

La Parte 3 y las evidencias A–D del caso

CUBRE

Los ocho sistemas, uno por uno

NATURALEZA

Caso ficticio con fines exclusivamente docentes

CÓMO SE USA ESTE ANEXO

De dónde salen los datos del inventario

La Parte 3 del caso les dice **qué sistemas** tiene Coopaburrá. Este anexo les dice **qué criptografía corre dentro de cada uno**: es el conjunto de configuraciones, volcados y salidas de comando que el equipo de diagnóstico recogió sistema por sistema.

Un inventario criptográfico no se construye con la descripción comercial de un sistema, sino con artefactos como estos. Cada ficha trae la salida real de una herramienta y una nota breve de **cómo leerla**. Con eso pueden llenar, para casi todos los sistemas, las columnas de algoritmo y de llave que en el caso solo aparecían como «desconocido».

TRES ADVERTENCIAS ANTES DE EMPEZAR

Uno. Este anexo no reemplaza al caso: lo complementa. Las evidencias A, B, C y D siguen estando en la Parte 8 del caso y no se repiten aquí. **Dos.** Leer un artefacto no es lo mismo que llenar la fila: el anexo dice qué algoritmo hay, pero *para qué sirve, quién responde y cuándo se rota* los siguen deduciendo ustedes con las Partes 2, 7 y 10. **Tres.** Aun con este anexo, **dos cosas quedan sin determinar a propósito**, y están en la última página: marcarlas como desconocidas, con destinatario, sigue siendo parte del trabajo.

Cómo leer una salida de comando que no conocen

No hace falta haber usado la herramienta. Cada ficha señala el dato que importa. Busquen tres cosas en cada artefacto:

El nombre del algoritmo

AES, RSA, SHA-1, 3DES, MD4... casi siempre aparece literal. Anótenlo con su modo y su longitud si están.

Dónde está la llave

Una ruta de archivo, un almacén, «cargada manualmente», «en el código». Eso llena la columna de la llave.

Qué no aparece

Si no hay rotación, ni sal, ni segundo factor, esa ausencia es un dato, no un vacío. Anótenla.

LA FECHA DE ESTOS ARTEFACTOS

Todos se recogieron durante las dos semanas del diagnóstico, en febrero de 2026. Son una foto del momento: un inventario dice lo que había ese día, no lo que debería haber. Si algo cambió después, es material de otra entrega.

SISTEMA 1 DE 8 · CORE FINANCIERO

Servidor de base de datos en Itagüí

Operado por NúcleoCoop S.A.S. Base relacional de 2,3 TB. Se recogieron dos cosas: cómo está cifrado el disco y cómo se accede a la base.

ARTEFACTO 1 · CIFRADO DEL DISCO

```
CRYPTSETUP LUKSDUMP /DEV/SDB
# root@core-db:~# cryptsetup luksDump /dev/sdb
LUKS header information
Version:          2
Data segments:
  0: crypt
    offset: 16777216 [bytes]
    cipher: aes-xts-plain64
    sector: 512 [bytes]
Keyslots:
  0: luks2
    Key:          512 bits
    PBKDF:        argon2id
    Time cost:    4
    Memory:       1048576 [KiB]
```

Cómo se lee: el disco está cifrado con **AES en modo XTS**, con llave de 512 bits (el modo XTS usa dos mitades, así que son 256 bits efectivos de AES) y la contraseña de arranque protegida con Argon2id. Es un cifrado de disco correcto y moderno. Pero recuerden lo que dice el hallazgo H3: protege el disco **apagado**. Con el servidor encendido, la base responde en claro.

ARTEFACTO 2 · ACCESO A LA BASE DE DATOS

```
POSTGRESQL.CONF · PG_HBA.CONF
# postgresql.conf
ssl = off

# pg_hba.conf — quién se conecta y cómo
# TYPE DATABASE USER ADDRESS METHOD
host all all 10.0.0.0/8 md5
# 11 cuentas con acceso de solo lectura a todas las tablas
```

Cómo se lee: **no hay cifrado de la conexión** a la base (`ssl = off`): las consultas viajan en claro por la red interna. La contraseña de acceso usa md5, que es el mecanismo de autenticación de PostgreSQL, no un cifrado de los datos. Y **no hay cifrado por columna**: cédula, saldo y movimientos están en texto plano dentro de la tabla. El contrato con NúcleoCoop no permite cambiar el esquema, así que agregar cifrado de campo no es trivial. Aquí hay dos usos distintos que van en dos filas: el disco y la base en operación.

SISTEMA 2 DE 8 · PORTAL DE ASOCIADOS

La configuración del canal del portal

Aplicación web propia, 2019. La evidencia A del caso ya trae el resultado de la revisión del canal; aquí está la configuración que lo produce, que es lo que habría que cambiar. Las contraseñas del portal son la evidencia B y no se repiten.

ARTEFACTO 3 · CONFIGURACIÓN TLS DEL SERVIDOR WEB

```
/ETC/NGINX/CONF.D/PORTAL.CONF
server {
    listen 443 ssl;
    server_name portal.coopaburra.com;

    ssl_protocols      TLSv1 TLSv1.1 TLSv1.2;
    ssl_ciphers         ECDHE-RSA-AES256-SHA:AES256-SHA:DES-CBC3-SHA;
    ssl_prefer_server_ciphers on;

    ssl_certificate     /etc/ssl/portal.crt;    # emisor: Coopaburra Root CA 2019
    ssl_certificate_key /etc/ssl/portal.key;    # RSA 2048
}
```

Cómo se lee: el servidor acepta **TLS 1.0, 1.1 y 1.2** —las dos primeras versiones están retiradas desde 2021— y su lista de suites incluye **AES256-SHA** (intercambio de llave RSA, sin confidencialidad futura) y **DES-CBC3-SHA**, que es **3DES**, un algoritmo en desuso. El certificado lo emite la autoridad interna, «Coopaburra Root CA 2019», y la llave privada es RSA de 2048 bits. Esto es exactamente lo que la evidencia A observó desde afuera; ahora saben desde dónde se cambia. Es material para el laboratorio 5.

POR QUÉ EL PORTAL GENERA TRES FILAS DEL INVENTARIO, NO UNA

De esta sola configuración salen tres usos distintos: el **canal** (las versiones y suites de arriba), el **certificado** que identifica al servidor (RSA 2048, SHA-256, emitido por la CA interna) y las **contraseñas** que el portal guarda (evidencia B). Tres algoritmos, tres llaves, tres problemas. Si los juntan en una fila, el inventario esconde justo lo que debe revelar.

SISTEMA 3 DE 8 · APLICACIÓN MÓVIL

El canal entre la aplicación y el core

Desarrollada por Bitlab S.A.S. La firma de las operaciones es la evidencia D del caso. Lo que faltaba —cómo viaja la operación desde el teléfono hasta el core— está aquí.

ARTEFACTO 4 · POLÍTICA DE RED DE LA APLICACIÓN ANDROID

```
RES/XML/NETWORK_SECURITY_CONFIG.XML (EXTRAÍDO DEL APK)
<network-security-config>
  <domain-config cleartextTrafficPermitted="true">
    <domain includeSubdomains="true">svc-intermedio.coopaburra.local</domain>
  </domain-config>
  <base-config cleartextTrafficPermitted="false">
    <trust-anchors><certificates src="system" /></trust-anchors>
  </base-config>
</network-security-config>
```

Cómo se lee: la aplicación habla con internet por HTTPS (bien), **pero hace una excepción:** al servicio intermedio que la conecta con el core, `svc-intermedio.coopaburra.local`, le permite tráfico **en claro** (`cleartextTrafficPermitted="true"`). Es decir: entre el borde de la nube y el core, las operaciones —hasta 61.000 los días de pago— pueden viajar sin cifrar por la red interna.

ARTEFACTO 5 · EL SERVICIO INTERMEDIO, VISTO DESDE LA RED INTERNA

```
CURL -SI HTTP://SVC-INTERMEDIO.COOPABURRA.LOCAL:8080/HEALTH
$ curl -sI http://svc-intermedio.coopaburra.local:8080/health
HTTP/1.1 200 OK
Server: nginx
X-App: coopaburra-bridge/1.4
# responde por HTTP plano en el puerto 8080; no hay redirección a HTTPS
```

Cómo se lee: el servicio intermedio contesta por **HTTP sin cifrar**. Confirma lo anterior: el tramo interno del canal no está protegido. Este es el uso que en el caso figuraba como «desconocido»; ahora tiene respuesta. La firma de cada operación (HMAC-SHA256, evidencia D) es un uso aparte y ya la conocen.

SISTEMA 4 DE 8 · RED DE CAJEROS

El registro de carga de llaves

32 cajeros propios. El caso decía que las llaves «se cargaron manualmente en 2019 y nunca se rotaron». Se encontró el acta de esa carga, que además revela el algoritmo.

ARTEFACTO 6 · ACTA DE CEREMONIA DE LLAVES, 2019

REGISTRO DE LA PUESTA EN MARCHA · RED DE CAJEROS

ENTIDAD:	Coopaburra	FECHA:	2019-03-11
Tipo de llave maestra (TMK):	TDES / 3DES, doble longitud (112 bits)		
Estándar de intercambio:	ninguno (TR-31 no utilizado)		
Método de carga:	componentes en claro, tecla a tecla		
Custodios:	2 operadores (uno ya no labora en la entidad)		
KCV (valor de comprobación):	A3F1C0		
Rotación programada:	no		
Doble control / ceremonia:	no documentado		

Cómo se lee: las llaves de comunicación de los cajeros son **3DES (TDES) de doble longitud**, unos 112 bits de seguridad. 3DES sigue en uso en redes de cajeros antiguas, pero está en camino a su retiro. Lo grave no es solo el algoritmo: se cargaron **en claro, tecla a tecla**, sin el estándar TR-31 que envuelve las llaves, sin doble control y **sin rotación**. El fabricante recomienda rotar cada dos años; van siete. Uno de los dos custodios ya no trabaja allí. Es el hallazgo H6, ahora con nombre de algoritmo.

PARA EL LABORATORIO 6

Esta es la llave que en el laboratorio 6 van a repartir entre cinco custodios con umbral de tres. El acta explica por qué hace falta: hoy la llave dependió de dos personas y de un procedimiento sin registro.

SISTEMA 5 DE 8 · PROCESADOR DE TARJETAS

El canal con el proveedor externo

Autoriza las transacciones de la tarjeta débito. Es, con diferencia, el sistema mejor llevado del caso: sirve para ver cómo se ve un uso criptográfico correcto.

ARTEFACTO 7 · REVISIÓN DEL CANAL DE AUTORIZACIÓN

```
OPENSLL S_CLIENT -CONNECT AUTH.PROCESADOR.EXAMPLE:443
Protocol   : TLSv1.3
Cipher     : TLS_AES_256_GCM_SHA384
Peer certificate: CN = auth.procesador.example
Verify return code: 0 (ok)
Client certificate requested: yes    # autenticación mutua (mTLS)
```

Cómo se lee: el canal usa **TLS 1.3 con AES-256-GCM** —cifrado autenticado, la mejor opción— y **autenticación mutua**: el proveedor exige que Coopaburrá presente su propio certificado de cliente. La cadena verifica sin advertencias. Sobre el almacenamiento, el caso ya lo dice: Coopaburrá **no guarda el número completo** de la tarjeta, solo los primeros seis y los últimos cuatro dígitos. En el inventario, esta fila se llena casi toda con datos «correctos»: sirve de contraste frente a los demás.

LO QUE AQUÍ SÍ QUEDA DESCONOCIDO, Y POR QUÉ

Lo que el proveedor hace **de su lado** con las llaves —cómo las genera, dónde las guarda, cada cuánto las rota— está bajo su propio alcance de cumplimiento PCI y **no se comparte con Coopaburrá**. En el inventario esto se registra como «gestionado por el proveedor, no divulgado», con la nota de que se puede solicitar su certificación PCI. Es un «desconocido» legítimo, con destinatario.

SISTEMA 6 DE 8 · GESTOR DOCUMENTAL

Cómo se firma y se guarda un pagaré

1,1 millones de documentos, los más antiguos de 2009. El caso dice que los pagarés se «firman» con una imagen escaneada. Aquí está la comprobación, y cómo se guardan.

ARTEFACTO 8 · ¿TIENE FIRMA DIGITAL EL PAGARÉ?

```
PDFSIG CONTRATO_HIPOTECARIO_2026.PDF
$ pdfsig contrato_hipotecario_2026.pdf
File 'contrato_hipotecario_2026.pdf' does not contain any signatures

$ mutool show contrato_hipotecario_2026.pdf grep
# ...
/Type /XObject /Subtype /Image # la "firma" es una imagen incrustada
```

Cómo se lee: la herramienta que verifica firmas digitales dice que el documento **no contiene ninguna firma**. Lo que hay es una **imagen** de la firma, incrustada en el PDF como cualquier logo. No hay firma digital, ni sello de tiempo, ni autoridad de certificación. En la columna de algoritmo, la respuesta correcta es «ninguno». Es el hallazgo H7, y el documento debe conservar valor probatorio hasta 2039.

ARTEFACTO 9 · DÓNDE VIVEN ESOS DOCUMENTOS

```
SMBCLIENT · RECURSO COMPARTIDO DEL GESTOR
$ smbclient -L //fileserver/gestor
      Sharename      Type      Comment
      ----
      gestor         Disk      Contratos y pagares
Cifrado en reposo: ninguno # archivos PDF en un recurso SMB, sin cifrar
```

Cómo se lee: los documentos están en un recurso compartido de archivos, **sin cifrado en reposo**. Es un segundo uso (o su ausencia) que va en su propia fila.

SISTEMAS 7 Y 8 DE 8 · CORREO Y DIRECTORIO

Correo en la nube y directorio local

380 buzones en la nube y un directorio local que autentica a los empleados en los sistemas internos. Dos sistemas, dos fichas.

ARTEFACTO 10 · SEGURIDAD DEL CORREO

REVISIÓN DEL DOMINIO DE CORREO · COOPABURRA.COM

Entrega SMTP entrante/saliente: **STARTTLS** (oportunista)
Registro SPF: **no publicado**
Registro DKIM: **no publicado**
Registro DMARC: **no publicado**
Segundo factor (MFA): **no habilitado**

Cómo se lee: el correo viaja cifrado **cuando el otro extremo lo admite** (STARTTLS oportunista), lo cual es correcto pero no garantizado. Lo que falta es lo importante: **sin SPF, DKIM ni DMARC**, cualquiera puede enviar un correo que aparente venir de Coopaburrá y nadie lo detecta. Es exactamente el fraude del «correo del gerente» que vieron en la sesión 1. El cifrado en reposo del buzón lo gestiona el proveedor de nube y no está documentado del lado de Coopaburrá.

ARTEFACTO 11 · ALMACENAMIENTO DE CREDENCIALES DEL DIRECTORIO

DIRECTORIO DE USUARIOS LOCAL · ALMACENAMIENTO DE CONTRASEÑAS

Tipo de resumen almacenado: **NT hash (MD4, sin sal)**
Enlace de autenticación: **LDAP simple bind, puerto 389 (sin TLS)**
Usuarios: **380 empleados**

Cómo se lee: el directorio guarda las contraseñas de los 380 empleados como **NT hash**, que es **MD4 sin sal** —más débil todavía que el SHA-1 del portal— y las valida por **LDAP simple bind en el puerto 389, sin cifrar**: la contraseña viaja en claro por la red interna en cada inicio de sesión. Son dos filas del inventario: cómo se guardan y cómo viajan.

CIERRE

Lo que sigue sin determinar, a propósito

Un inventario honesto tiene casillas que dicen «desconocido». Con este anexo son pocas, pero existen, y marcarlas bien —con la razón y con a quién pedirle el dato— es tan importante como llenar las demás.

QUÉ NO SE PUDO DETERMINAR	POR QUÉ	A QUIÉN SE LE PIDE
La gestión de llaves del procesador de tarjetas	Está bajo el alcance PCI del proveedor y no se comparte con Coopaburrá	Al proveedor, su certificación PCI vigente
El cifrado en reposo del correo en la nube	Lo gestiona el proveedor de nube; Coopaburrá no administra esas llaves	Al proveedor de nube, su documentación de cifrado

CÓMO CAMBIA ESTO EL INVENTARIO

Con el caso solo, seis de los sistemas quedaban en «desconocido» por falta de información. Con este anexo, esos «desconocido» pasan a ser datos reales: AES-XTS en el disco del core, HTTP en claro en el tramo interno de la aplicación, 3DES en los cajeros, TLS 1.3 con el procesador, MD4 en el directorio. Lo que queda sin determinar son solo las dos filas de arriba, y por una razón legítima: dependen de terceros. Eso es lo que distingue un «no lo levantamos» de un «no nos corresponde levantarlo».

Resumen de lo que aporta cada ficha

SISTEMA	LO QUE ESTE ANEXO PERMITE ESCRIBIR EN EL INVENTARIO
Core · disco	AES-256-XTS, contraseña de arranque con Argon2id
Core · base en operación	Sin cifrado de conexión (ssl off) ni de columna; acceso de 11 cuentas
Portal · canal	TLS 1.0–1.2, suites con RSA y 3DES; certificado de la CA interna
App móvil · canal al core	HTTP en claro en el tramo interno, vía el servicio intermedio
Cajeros	3DES doble longitud, carga manual, sin TR-31 ni rotación
Procesador	TLS 1.3 con AES-GCM y autenticación mutua; PAN truncado
Gestor documental	Sin firma digital (imagen); sin cifrado en reposo
Correo	STARTTLS oportunista; sin SPF/DKIM/DMARC ni MFA
Directorio local	NT hash (MD4 sin sal); LDAP en claro en el puerto 389

ADVERTENCIA SOBRE LA NATURALEZA DEL CASO

Coopaburrá no existe. Las configuraciones, salidas y actas de este anexo son verosímiles y están construidas para el módulo, pero no corresponden a ninguna entidad, sistema ni persona real.